

Contents

1	FR20: アクセス制御細部	1
1.1	0. 文書情報	1
1.2	1. 機能概要	1
1.3	2. 収録 FR-NNN 一覧	1
1.4	3. 補足説明・統合参照	2
1.5	4. 関連設計	2
1.6	5. 未確定事項・確認事項	2

1 FR20: アクセス制御細部

1.1 0. 文書情報

項目	内容
文書名	FR20: アクセス制御細部
機能グループ	アクセス制御細部
対象システム	FAQ AI ウィジェット SaaS / メインシステム
作成日	2026-05-17
版数	v1.0
ステータス	承認済

1.2 1. 機能概要

項目	内容
概要	プロジェクト単位 IP 許可リスト (ウィジェットアクセス制限)、海外 IP 遮断 (運営者画面のみデフォルト ON)、複数デバイス同時ログイン、オーナーの退会・停止・削除・降格・譲渡の不可制約、自己操作不可制約、メンバーの1オーナー固定、プロジェクト別ロール選択 UI、ダッシュボードの権限不問アクセス、ロール変更後のセッション扱い、未割当メンバーの 403 拒否を扱う
利用場面	プロジェクトごとのウィジェット IP 制限導入、運営者の海外 IP 制限、ユーザー管理画面でのプロジェクト別ロール変更、URL 直アクセス時の拒否
優先度	Must

1.3 2. 収録 FR-NNN 一覧

ID	要件	優先度
FR-330	IP 許可リスト (FAQ ウィジェット向け、プロジェクト単位) を設定できること。設定権限はオーナー専有 (プロジェクト設定の一部)。入力形式、許容範囲、検証方式、評価対象スコープ (ウィジェット系エンドポイントのみ / 管理 API 系は対象外) は基本設計を正本とする	P1
FR-331	海外 IP 遮断は運営者画面のみデフォルト ON とする。利用者側 API およびウィジェットは海外エンドユーザーから到達するため対象外	P1
FR-332	同一アカウントの複数デバイス同時ログインは可能とし、SCR-001 でアクティブセッション一覧を確認可能にすること。運営者は連携 IF #2 で強制ログアウトを実行できる	P0
FR-333	オーナーは退会・停止・削除・降格・譲渡の不可制約とすること。1アカウント=1オーナーの自存により、orphan 状態は構造的に発生しない。オーナー譲渡機能は MVP 対象外とし、緊急時はサポート窓口経由の運営者対応とする	P0
FR-334	利用者 (オーナー / メンバー) は自分自身の利用状態変更・削除・ロール降格・プロジェクト割当変更不可とすること。特に自分が admin ロールを持つ最後のプロジェクトで自身を降格する操作 (admin → member / 割当削除) は不可で、別の admin 保持者 (またはオーナー) 経由で実行する必要がある	P0
FR-335	メンバーは1アカウント=1オーナー配下に固定し、同一メールアドレスでも別オーナー配下では別アカウントとして扱うこと	P1
FR-336	プロジェクト別ロールの指定は当該プロジェクトごとに「割当しない / メンバー / 管理者」の3値ラジオで行うこととし、契約横断のプリセットロールは MVP では持たないこと。プリセット導入は Future 検討事項とする	P0

ID	要件	優先度
FR-337	ダッシュボード(自分の通知・お知らせ受信箱)は、オーナーおよびメンバーが閲覧できること(メンバーは常に最低1件の割当を保持する不変条件 FR-015d により、ダッシュボード閲覧可否は割当有無に依存しない)。それ以外の画面はそれぞれのロールとプロジェクト境界を要求する	P0
FR-338	プロジェクト別ロールおよびプロジェクト割当の追加・剥奪はアクティブセッションを即時失効させず、次回認可チェック時点で反映することで足りること。反映上限時間とキャッシュ方式は基本設計を正本とする	P1
FR-339	メンバーアカウントは「常に最低1件のプロジェクト割当を保持する」不変条件 (FR-015d) を満たすこと。割当が0件になる経路をすべて事前ブロックすること: (a) 招待時に最低1件の割当を必須化 (FR-015)、(b) ロール一括変更で結果割当が0件となる場合は API / 画面で拒否 (FR-018a)、(c) 個別の割当取消で最後の1件を取り消す操作は拒否しオーナーへのアカウント完全削除依頼に誘導 (FR-018c / FR-019)、(d) プロジェクト削除起因で他プロジェクト割当が0件かつ is_owner=0 となるメンバーは accounts ごと物理削除 (FR-030b)。SCR-029 割当ゼロホームは MVP では設けず、管理コンソール側で割当ゼロ状態は構造的に発生しないことを前提に設計すること。プロジェクト帰属データへの URL 直入力アクセスは引き続き 403 拒否 (該当 account_project_grants 行を持たない場合)	P0
FR-340	管理コンソールの全認証後画面で、現在の操作者ロール(オーナー / プロジェクトワークスペース内では当該プロジェクトに対する admin / member)を画面右上のロールバッジで常時可視化すること。複合ロール(他プロジェクトでは admin、当該プロジェクトでは member 等)の場合は現在地のワークスペースで適用されるロールを表示する	P0
FR-341	権限不足で操作不可なボタン・トグル等は、単純な非活性化のみではなく、ホバー / フォーカス時に「必要な権限」と「依頼先(同一プロジェクトの admin 保持者一覧 + オーナー)」を提示できること。403 を実際に踏んだ場合は画面上部に同等の説明バナーを表示すること (基本設計 §4 を正本とする)	P0

1.4 3. 補足説明・統合参照

(該当なし。権限マトリクス本体は § 6.2 を、ロール定義は § 6.2.0 を、プロジェクト境界は § 6.2.0a を、緊急区分の客観条件は § 6.2.1 / § 6.2.2 を参照)

1.5 4. 関連設計

種別	参照先
画面設計	../02_基本設計/01_画面設計.md
API 設計	../02_基本設計/02_API 設計.md
テーブル設計	../02_基本設計/03_テーブル設計.md
権限設計	../02_基本設計/04_権限設計.md
エラー設計	../02_基本設計/05_エラー設計.md
メッセージ	../02_基本設計/06_メッセージ一覧.md
認証・認可設計	../02_基本設計/08_認証・認可設計.md
詳細設計	../03_詳細設計/index.md

1.6 5. 未確定事項・確認事項

確認事項 ID	確認内容	優先度	ステータス
-	v1.0 リリース時点で全項目確定済み	低	確認済